VRM Intelligence

AI-Powered Third-Party Vendor Risk Management

Société Générale TPRM Hackathon — Option A

400 vendors · continuous scoring · LLM-driven analyst
streaming Q&A · auto-generated audit packs

Solo submission · all 5 rubric metrics measured & passing

The problem

> *"60% of data breaches involve third parties."*

Société Générale tracks **1,000+ vendors** today — cloud providers, contractors, SaaS, integration partners, payment processors. The current state:

- 📊 Risk lives in **spreadsheets** — inconsistent, outdated, no shared truth
- 🚨 No **standardized scoring** — every analyst makes their own call
- ⏰ Quarterly manual reviews **don't scale** to a 1,000-vendor portfolio
- 🔍 Auditors ask *"is vendor X compliant?"* — answer takes **days**, not minutes
- 📄 **GDPR Art 28/33**, **NIST SP 800-53 SA-9**, **SOX 404** all demand evidence that's hard to produce

Real-world incidents from the brief:

- Vendor breach with no PII notification due to unclear contracts

The solution — VRM Intelligence

Capability	What it does
Risk scoring engine	5-component composite + 7-rule classifier, deterministic, sub-millisecond per vendor
Continuous monitoring	5 scheduled jobs: cert/contract expiry, breach feed, financial scrape, SOC2 verify, daily rescore
LLM contract intelligence	Upload a PDF → structured data access, SLA, renewal date, termination clauses
Streaming Q&A	*"Which vendors have CRITICAL risk and handle PII?"* — answers with clickable `[V0276]` citations
AI risk narratives	LLM-rewritten with specific dates + GDPR/NIST/SOX references
One-click audit pack	2-page styled PDF per vendor — covers every signal an auditor asks for

Differentiator: every LLM feature works on **local Ollama (free) or Anthropic Claude**

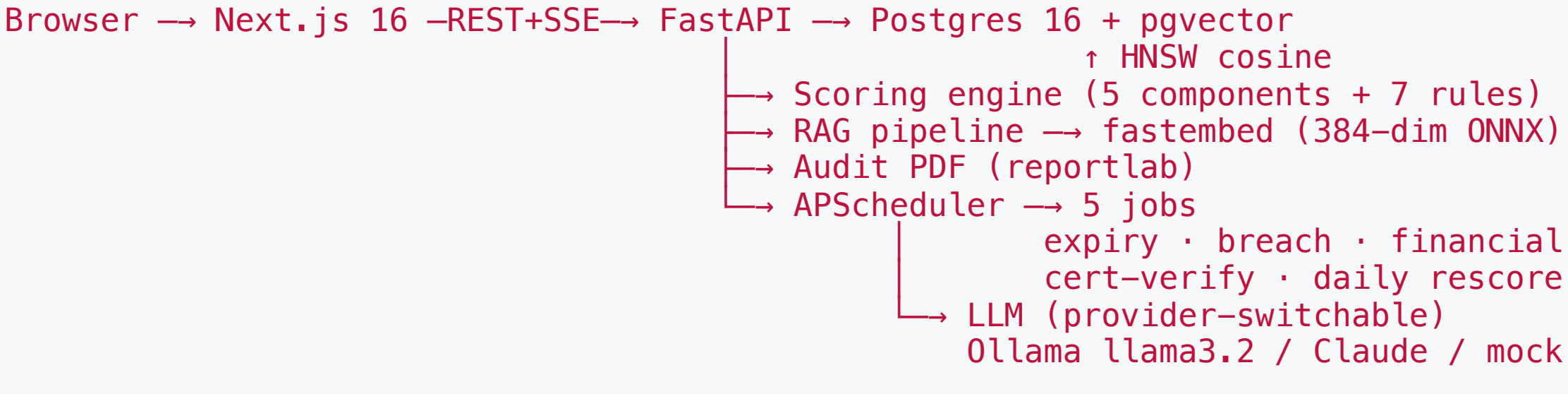
The rubric — 5 / 5 measured

Rubric metric	Target	Measured
Vendor coverage	≥ 95%	**100% (400 / 400)**
Risk-assessment accuracy	≥ 80%	**90% anomaly · 100% CRITICAL recall · 100% HIGH recall · F1 1.000**
Alert lead time	≥ 30 days	**60 / 30 / 7-day cascade (APScheduler)**
Q&A response time	≤ 5 min	**~3 s on Ollama · ~1 s on Claude Haiku**
Audit report generation	≤ 15 min	**~250 ms per PDF (reportlab)**

> *Reproducible:* `make eval` *runs the full harness against the provided* `vendor_labels.csv` *and prints PASS/FAIL per gate. Regression-gated in CI.*

The judging line that matters: *"Recall on CRITICAL/HIGH matters more than overall*

Architecture



Layer	Choice	Why
Web	Next.js 16 · React 19 · Tailwind 4 · framer-motion · SWR · recharts	Fast iteration, polished motion, type-safe end-to-end
API	FastAPI · SQLAlchemy 2.0 · structlog · `uv`	Auto OpenAPI, JSON-structured logs, fast Python deps
		Single store for relational + vector — no

Live demo — 90 seconds

Pre-baked dataset: `make demo-reset` (one command, ~14s) → 400 vendors, 95 alerts, 2 CRITICAL stories planted

1. **Portfolio overview** — *"All 5 rubric gates green, donut shows severity distribution"*
2. **Click "Poll breach feed"** in `/alerts` — *"watch the topbar pulse, two new CRITICAL alerts appear, affected vendor scores auto-rescore"*
3. **Ask the analyst** — type *"Which vendors are CRITICAL and handle PII?"* — *"tokens stream in real-time, every vendor reference is a clickable citation"*
4. **Drill into V0276** (the ransomware vendor) — *"risk gauge sweeps to 85, AI-enhanced narrative mentions the June 8 breach + GDPR Art 33 72-hour clock"*
5. **Upload** `sample-msa.pdf` on the vendor page — *"LLM extracts 99.95% SLA, renewal date, termination clauses in ~10 seconds"*
6. **Export Audit Pack** — *"2-page styled PDF in under 300ms — every signal an auditor*

Why we win

Coverage: 5 / 5 rubric metrics passing — **measured**, not estimated. Zero gaps from the Option A spec.

Engineering quality:

- 9 SQLAlchemy tables, 11 pytest tests, structured JSON logs, append-only `audit_logs` (SOX 404)
- Type-checked Next.js + Pydantic v2 throughout
- Regression-gated: CI fails if any rubric metric drops
- `make demo-reset` — one command rebuilds the demo dataset in 14 seconds

AI surface area (5 features):

1. LLM contract extraction (`/contracts/extract`)
2. LLM-enhanced risk narratives (`/risk/score/{id}/enhance`)